

Executive Decision Brief — NexaLearn Digital Services Limited

Purpose

This report summarises the most urgent risks identified during the GRC assessment, the key decisions the Board needs to make, what the recent security incident could mean for NexaLearn legally, and where the organisation should focus its time and resources over the next 90 days.

Top Three Risks

Shared administrator access: Three technical staff currently use the same emergency administrator account. This means there is no clear way to know who carried out an action using the account if something goes wrong.

Delayed removal of access when people leave: A former contractor's account was still active 37 days after their contract ended. This creates a risk because someone who is no longer working with NexaLearn could still have access to its systems or information.

Customer-support vendor contract gap: The customer-support vendor has access to learner information, but the contract does not clearly state the data protection requirements or what the vendor needs to do if a breach happens. This leaves NexaLearn exposed to privacy and compliance risks.

The Governance Decision Needed

The Board needs to decide whether the AI-assisted admissions tool should still be launched in three months as planned or if the launch should be delayed until the right governance arrangements are in place. This should include having a human oversee the system, clearly defining who is responsible for it and regularly checking that it is not producing unfair or incorrect outcomes. Launching the tool without these measures could create compliance and reputational problems for NexaLearn.

Regulatory Implications of the Incident

During the recent security incident, learner records were briefly made publicly accessible and about 1,240 records were downloaded from an unfamiliar IP address. At the time of the assessment, no regulator or affected learner had been notified. The incident may create notification and other compliance obligations under the Nigeria Data Protection Act and potentially the GDPR, depending on whether the GDPR applies to NexaLearn's EEA learners. NexaLearn should assess the incident and confirm what notification obligations apply.

90-Day Investment Priorities

- Remove the shared administrator account and improve the process for removing access when employees and contractors leave.
- Fix the cloud storage permissions and improve monitoring so that learner information is not accidentally made public again.
- Update the customer-support vendor contract to include proper data protection and breach notification requirements.
- Improve the incident response process by clearly defining escalation and regulatory notification procedures.
- Put proper AI governance and human oversight in place before deploying the AI-assisted admissions screening tool.

Decision Requested

The Board is asked to approve the budget and staff time needed to address the main access, cloud security, incident response and vendor risks within the 90-day improvement period. The Board is also asked to decide whether the planned AI-assisted admissions tool should launch as scheduled or be delayed until the required governance and human oversight arrangements are properly documented and in place.